

SIMULACION Y MITIGACION DE ATAQUE DoS

Instalación de aplicaciones

Instalamos Hping3 en la maquina atacante

```
victor@victor-hping:~$ sudo apt install hping3 -y
[sudo] password for victor:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following NEW packages will be installed:
  hping3
0 upgraded, 1 newly installed, 0 to remove and 264 not upgraded.
Need to get 106 kB of archives.
After this operation, 263 kB of additional disk space will be used.
Get:1 http://es.archive.ubuntu.com/ubuntu jammy/universe amd64 hping3 amd64 3.a2.ds2-10 [106 kB]
Fetched 106 kB in 1s (169 kB/s)
Selecting previously unselected package hping3.
(Reading database ... 180022 files and directories currently installed.)
Preparing to unpack .../hping3_3.a2.ds2-10_amd64.deb ...
Unpacking hping3 (3.a2.ds2-10) ...
Setting up hping3 (3.a2.ds2-10) ...
Processing triggers for man-db (2.10.2-1) ...
victor@victor-hping:~$
```

Instalamos fail2ban en la maquina victima

```
victor@victor-fail2ban:~$ sudo apt install fail2ban
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  python3-pyinotify whois
Suggested packages:
  mailx monit sqlite3 python-pyinotify-doc
The following NEW packages will be installed:
  fail2ban python3-pyinotify whois
0 upgraded, 3 newly installed, 0 to remove and 264 not upgraded.
Need to get 473 kB of archives.
After this operation, 2.486 kB of additional disk space will be used.
Do you want to continue? [Y/n] y
```

Configuración Fail2ban puerto 22 SSH

Creamos un archivo de configuración jail.local a partir de jail.conf

```
victor@victor-fail2ban:~$ sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local
```

Con nano configuramos la regla para SSH.

```
[sshd]
# To use more aggressive sshd modes set filter parameter "mode" in jail.local:
# normal (default), ddos, extra or aggressive (combines all).
# See "tests/files/logs/sshd" or "filter.d/sshd.conf" for usage example and details.
#mode = normal
enabled = true
port = ssh
filter = sshd
logpath = /var/log/auth.log
maxretry = 3
bantime = 600
findtime = 60
backend = %(sshd_backend)s
```

Reiniciamos Fail2ban para aplicar los cambios.

```
victor@victor-fail2ban:~$ sudo systemctl restart fail2ban
victor@victor-fail2ban:~$
```

Simulamos el ataque con HPING

Desde nuestra maquina atacante mandamos paquetes SYN al puerto 22.

```
victor@victor-hping:~$ sudo hping3 -S --flood -p 22 192.168.30.132
HPING 192.168.30.132 (ens33 192.168.30.132): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
--- 192.168.30.132 hping statistic ---
445570 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
victor@victor-hping:~$
```

Podemos comprobar el envio con la captura de wireshark.

52849	8.421767724	192.168.30.131	192.168.30.132	TCP	54 19451 → 22 [RST]
52850	8.421764599	192.168.30.132	192.168.30.131	TCP	60 22 → 19452 [SYN,
52851	8.421770476	192.168.30.131	192.168.30.132	TCP	54 19452 → 22 [RST]
52852	8.421798870	192.168.30.131	192.168.30.132	TCP	54 19453 → 22 [SYN]
52853	8.421804643	192.168.30.131	192.168.30.132	TCP	54 19454 → 22 [SYN]
52854	8.421836848	192.168.30.131	192.168.30.132	TCP	54 19455 → 22 [SYN]
52855	8.421841739	192.168.30.131	192.168.30.132	TCP	54 19456 → 22 [SYN]
52856	8.421865087	192.168.30.132	192.168.30.131	TCP	60 22 → 19453 [SYN,
52857	8.421869099	192.168.30.131	192.168.30.132	TCP	54 19453 → 22 [RST]
52858	8.421865147	192.168.30.132	192.168.30.131	TCP	60 22 → 19454 [SYN,
52859	8.421872118	192.168.30.131	192.168.30.132	TCP	54 19454 → 22 [RST]
52860	8.421897488	192.168.30.132	192.168.30.131	TCP	60 22 → 19455 [SYN,
52861	8.421900853	192.168.30.131	192.168.30.132	TCP	54 19455 → 22 [RST]
52862	8.421897539	192.168.30.132	192.168.30.131	TCP	60 22 → 19456 [SYN,
52863	8.421903827	192.168.30.131	192.168.30.132	TCP	54 19456 → 22 [RST]
52864	8.421932717	192.168.30.131	192.168.30.132	TCP	54 19457 → 22 [SYN]
52865	8.421937631	192.168.30.131	192.168.30.132	TCP	54 19458 → 22 [SYN]
52866	8.421963464	192.168.30.131	192.168.30.132	TCP	54 19459 → 22 [SYN]
52867	8.421968335	192.168.30.131	192.168.30.132	TCP	54 19460 → 22 [SYN]
52868	8.421991560	192.168.30.132	192.168.30.131	TCP	60 22 → 19457 [SYN,
52869	8.421995312	192.168.30.131	192.168.30.132	TCP	54 19457 → 22 [RST]
52870	8.421991607	192.168.30.132	192.168.30.131	TCP	60 22 → 19458 [SYN,
52871	8.421998252	192.168.30.131	192.168.30.132	TCP	54 19458 → 22 [RST]
52872	8.422023856	192.168.30.132	192.168.30.131	TCP	60 22 → 19459 [SYN,

Desde la victima no aparece nada por parte de fail2ban, ya que a veces puede no detectar los ataques de hping3. Esto se debe a que fail2ban revisa logs, y en algunos casos hping satura la red impidiendo la creacion de entradas en el log, o los paquetes SYN no crean entrada.

```
victor@victor-fail2ban:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed:    0
| `-- File list:      /var/log/auth.log
`- Actions
   |- Currently banned: 0
   |- Total banned:    0
   `-- Banned IP list:
victor@victor-fail2ban:~$
```

Simulamos un ataque con login real con Hydra

Hydra nos permite realizar ataques de fuerza bruta completando el hadshake de ssh.

```
victor@victor-hping:~$ hydra -l invaliduser -p wrongpassword 192.168.30.132 ssh
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-17 19:22:10
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try per task
[DATA] attacking ssh://192.168.30.132:22/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-17 19:22:15
```

Ahora volvemos a revisar el estado fail2ban.

```
victor@victor-fail2ban:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
|- Filter
| |- Currently failed: 0
| |- Total failed:    3
| `-- File list:      /var/log/auth.log
`- Actions
   |- Currently banned: 1
   |- Total banned:    1
   `-- Banned IP list: 192.168.30.131
victor@victor-fail2ban:~$
```

Vemos que efectivamente se ha bloqueado la ip atacante tras 3 intentos fallidos de login.

Ahora comprobamos el log, y efectivamente, se han generado entradas por cada intento fallido hasta que fail2ban ha bloqueado el acceso a la IP atacante.

```
/auth.log' (pos = 0, hash = 246e83b8146b12163a6dc72dd0af4f2e6c161308)
2025-11-17 18:58:10,003 fail2ban.jail          [2791]: INFO    Jail 'sshd' started
2025-11-17 19:22:10,984 fail2ban.filter      [2791]: INFO    [sshd] Found 192.168.30.
131 - 2025-11-17 19:22:10
2025-11-17 19:22:11,006 fail2ban.filter      [2791]: INFO    [sshd] Found 192.168.30.
131 - 2025-11-17 19:22:11
2025-11-17 19:22:13,720 fail2ban.filter      [2791]: INFO    [sshd] Found 192.168.30.
131 - 2025-11-17 19:22:13
2025-11-17 19:22:13,758 fail2ban.actions     [2791]: NOTICE [sshd] Ban 192.168.30.13
1
AC
```

En conclusión, Fail2ban es una herramienta muy útil para generar sinergias con firewalls, ya que no bloquea a través de tráfico, sino de logs, lo cual la hace muy poderosa, pero solo si la configuramos adecuadamente.